MANAGEMENT INFORMATION SYSTEMS
ICT2162
LECTURE 09

Ms. Shelomi De Alwis
Department of ICT
Faculty of Technology
University of Ruhuna

Securing Information Systems

Intended Learning Objectives

- Identify organizations, Management, and the networked Enterprise.
- Explore Information Technology infrastructure and security of an organization.
- Explain Key System applications for the digital age.
- Identify how to build and manage information systems.

What We Discuss Today?

- Why information systems are vulnerable to destruction, error, and abuse
- Business value of security and control
- Components of an organizational framework for security and control
- Tools and technologies used for safeguarding information resources

Security & Controls

Security:

Policies, procedures, and technical measures used to prevent unauthorized access, alteration, theft, or physical damage to information systems

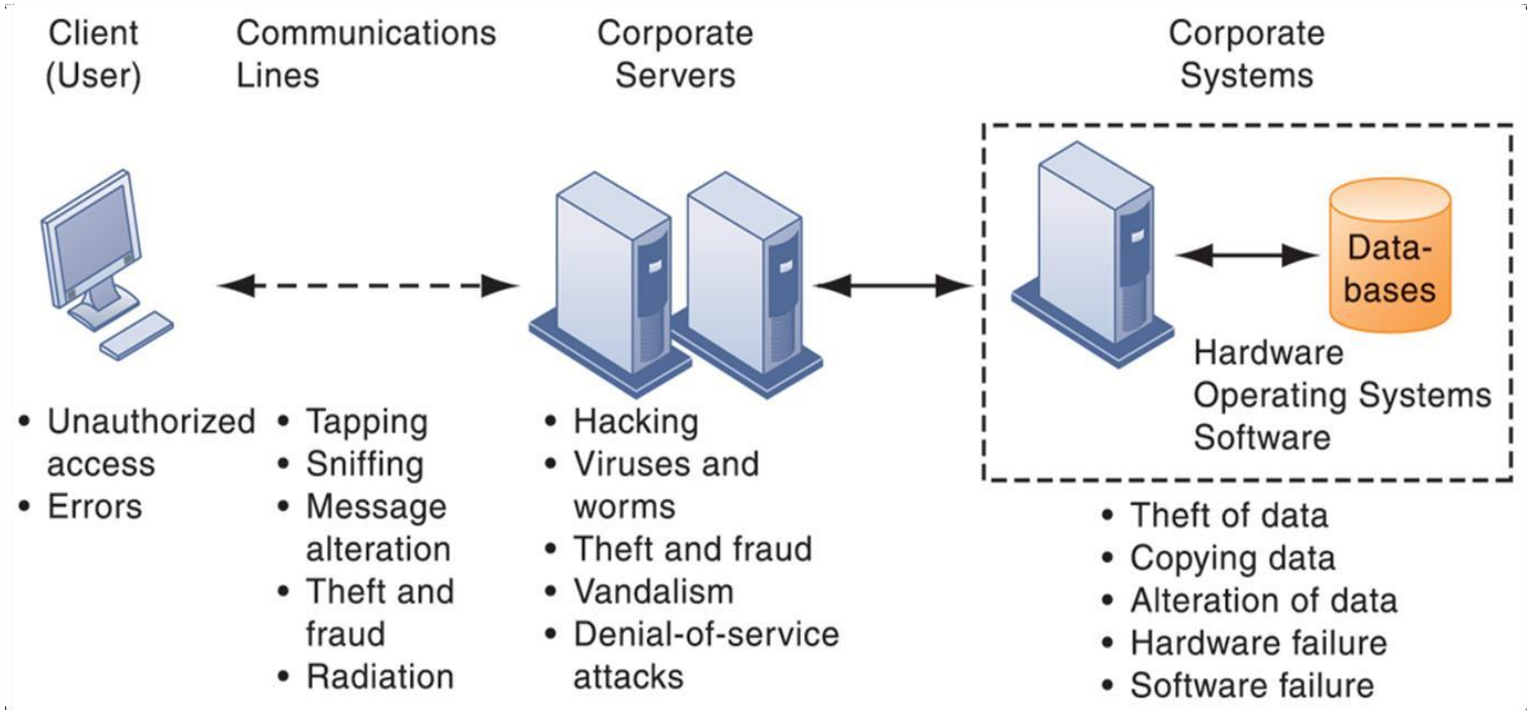
Controls:

Methods, policies, and organizational procedures that ensure safety of organization's assets; accuracy and reliability of its accounting records; and operational adherence to management standards

Why Systems are Vulnerable

1. Accessibility of networks
2. Hardware problems (breakdowns, configuration errors, damage from improper use or crime)
3. Software problems (programming errors, installation errors, unauthorized changes)
4. Disasters
5. Use of networks/computers outside of firm's control
6. Loss and theft of portable devices

Contemporary Security Challenges and Vulnerabilities



The architecture of a Web-based application typically includes a Web client, a server, and corporate information systems linked to databases. Each of these components presents security challenges and vulnerabilities. Floods, fires, power failures, and other electrical problems can cause disruptions at any point in the network

Internet Vulnerabilities

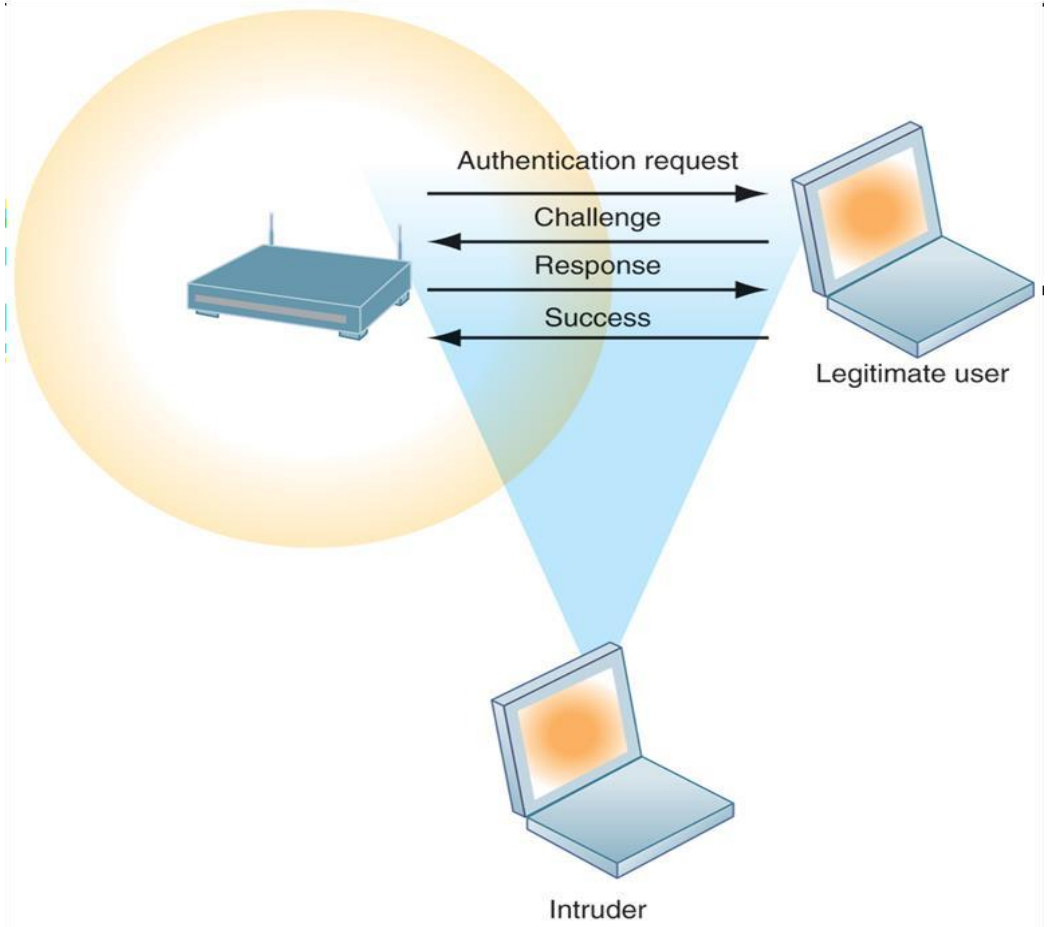
- Network open to anyone
- Size of Internet means abuses can have wide impact
- Use of fixed Internet addresses with cable / DSL modems creates fixed targets for hackers
- Unencrypted VOIP
- E-mail, P2P
  - Interception
  - Attachments with malicious software
  - Transmitting trade secrets

Wireless Security Challenges

- Radio frequency bands easy to scan
- SSIDs (service set identifiers)
  - Identify access points
  - Broadcast multiple times
  - Can be identified by sniffer programs
  - War driving

    Eavesdroppers drive by buildings and try to detect SSID and gain access to network and resources
  - Once access point is breached, intruder can use OS to access networked drives and files

Wi-Fi Security Challenges



Many Wi-Fi networks can be penetrated easily by intruders using sniffer programs to obtain an address to access the resources of a network without authorization

Malware (Malicious Software)

- Viruses
  - Rogue software program that attaches itself to other software programs or data files in order to be executed
- Worms
  - Independent programs that copy themselves from one computer to other computers over a network
- Worms and viruses spread by
  - Downloads (drive-by downloads)
  - E-mail, IM attachments
  - Downloads on Web sites and social networks

Malware (Malicious Software)

- Smartphones as vulnerable as computers
  - Study finds 13,000 types of smartphone malware
- Trojan horses
  - Software that appears benign but does something other than expected
- SQL injection attacks
  - Hackers submit data to Web forms that exploits site's unprotected software and sends rogue SQL query to database
- Ransomware

Malware (Malicious Software)

- Spyware
  - Small programs install themselves surreptitiously on computers to monitor user Web surfing activity and serve up advertising
  - Key loggers
    - Record every keystroke on computer to steal serial numbers, passwords, launch Internet attacks
  - Other types:
    - Reset browser home page
    - Redirect search requests
    - Slow computer performance by taking up memory

Hackers and Computer Crime

- Hackers vs. crackers
- Activities include:
  - System intrusion
  - System damage
  - Cyber vandalism
    - Intentional disruption, defacement, destruction of Web site or corporate information system

Hackers and Computer Crime

- Spoofing
  - Misrepresenting oneself by using fake e-mail addresses or masquerading as someone else
  - Redirecting Web link to address different from intended one, with site masquerading as intended destination

- Sniffer
  - Eavesdropping program that monitors information traveling over network
  - Enables hackers to steal proprietary information such as e-mail, company files, and so on

Hackers and Computer Crime

- Denial-of-service attacks (DoS)
  - Flooding server with thousands of false requests to crash the network
- Distributed denial-of-service attacks (DDoS)
  - Use of numerous computers to launch a DoS
  - Botnets
    - Networks of “zombie” PCs infiltrated by bot malware
    - Deliver 90 percent of world spam, 80 percent of world malware
    - Mirai botnet

Hackers and Computer Crime

Computer crime

- Defined as “any violations of criminal law that involve a knowledge of computer technology for their perpetration, investigation, or prosecution”
- Computer may be target of crime, for example:
  - Breaching confidentiality of protected computerized data
  - Accessing a computer system without authority
- Computer may be instrument of crime, for example:
  - Theft of trade secrets
  - Using e-mail for threats or harassment

Examples of Computer Crime

- **Computers as Targets of Crime**
  - Breaching the confidentiality of protected computerized data
  - Accessing a computer system without authority
  - Knowingly accessing a protected computer to commit fraud
  - Intentionally accessing a protected computer and causing damage, negligently or deliberately
  - Knowingly transmitting a program, program code, or command that intentionally causes damage to a protected computer
  - Threatening to cause damage to a protected computer

- **Computers as Instruments of Crime**
  - Theft of trade secrets
  - Unauthorized copying of software or copyrighted intellectual property, such as articles, books, music, and video
  - Schemes to defraud
  - Using e-mail for threats or harassment
  - Intentionally attempting to intercept electronic communication
  - Illegally accessing stored electronic communications, including e-mail and voice mail
  - Transmitting or possessing child pornography using a computer

Hackers and Computer Crime

- Identity theft
  - Theft of personal Information (social security ID, driver's license, or credit card numbers) to impersonate someone else
- Phishing
  - Setting up fake Web sites or sending e-mail messages that look like legitimate businesses to ask users for confidential personal data
- Evil twins
  - Wireless networks that pretend to offer trustworthy Wi-Fi connections to the Internet

Hackers and Computer Crime

- Pharming
  - Redirects users to a bogus Web page, even when individual types correct Web page address into his or her browser
- Click fraud
  - Occurs when individual or computer program fraudulently clicks on online ad without any intention of learning more about the advertiser or making a purchase
- Cyberterrorism and Cyberwarfare

Internal threats: Employees

- Security threats often originate inside an organization
- Inside knowledge
- Sloppy security procedures
  - User lack of knowledge
- Social engineering:
  - Tricking employees into revealing their passwords by pretending to be legitimate members of the company in need of information

Software Vulnerability

- Commercial software contains flaws that create security vulnerabilities
  - Hidden bugs (program code defects)
    - Zero defects cannot be achieved because complete testing is not possible with large programs
- Flaws can open networks to intruders
- Patches
  - Small pieces of software to repair flaws
  - Exploits often created faster than patches can be released and implemented

Vulnerabilities in Microprocessor Design

- Faulty(poor secure) designs of computer microprocessor chips, which enable hackers using malicious software programs to gain access to data that were thought to be completely protected.

- These vulnerabilities affect nearly every computer chip manufactured in the last 20 years.

Business Value of Security and Control

- Failed computer systems can lead to significant or total loss of business function.
- Firms now are more vulnerable than ever
  - Confidential personal and financial data
  - Trade secrets, new products, strategies
- A security breach may cut into a firm's market value almost immediately
- Inadequate security and controls also bring forth issues of liability

Business Value of Security and Control

- Legal and regulatory requirements for electronic records management and privacy protection
  - HIPAA: Medical security and privacy rules and procedures
  - Gramm-Leach-Bliley Act: Requires financial institutions to ensure the security and confidentiality of customer data
  - Sarbanes-Oxley Act: Imposes responsibility on companies and their management to safeguard the accuracy and integrity of financial information that is used internally and released externally

Electronic Evidence & Computer Forensics

- **Electronic evidence**
  - Evidence for white collar crimes often in digital form
    - Data on computers, e-mail, instant messages, e-commerce transactions
  - Proper control of data can save time and money when responding to legal discovery request
- **Computer forensics**
  - Scientific collection, examination, authentication, preservation, and analysis of data from computer storage media for use as evidence in court of law
  - Includes recovery of ambient and hidden data

Electronic Evidence & Computer Forensics

- Information systems controls
  - Manual and automated controls
  - General and application controls

- General controls
  - Govern design, security, and use of computer programs and security of data files in general throughout organization's information technology infrastructure
  - Apply to all computerized applications
  - Combination of hardware, software, and manual procedures to create overall control environment

Types of General Controls

1) Software controls
2) Hardware controls
3) Computer operations controls
4) Data security controls
5) Implementation controls
6) Administrative controls

Application Controls

- Specific controls unique to each computerized application, such as payroll or order processing
- Include both automated and manual procedures
- Ensure that only authorized data are completely and accurately processed by that application
- Include:
  - Input controls
  - Processing controls
  - Output controls

Risk Assessment

- Risk assessment: Determines level of risk to firm if specific activity or process is not properly controlled
  - Types of threat
  - Probability of occurrence during year
  - Potential losses, value of threat
  - Expected annual loss

EXPOSURE	PROBABILITY	LOSS RANGE (AVG)	EXPECTED ANNUAL LOSS
Power failure	30%	$5K–$200K ($102,500)	$30,750
Embezzlement	5%	$1K–$50K ($25,500)	$1,275
User error	98%	$200–$40K ($20,100)	$19,698

Security Policy

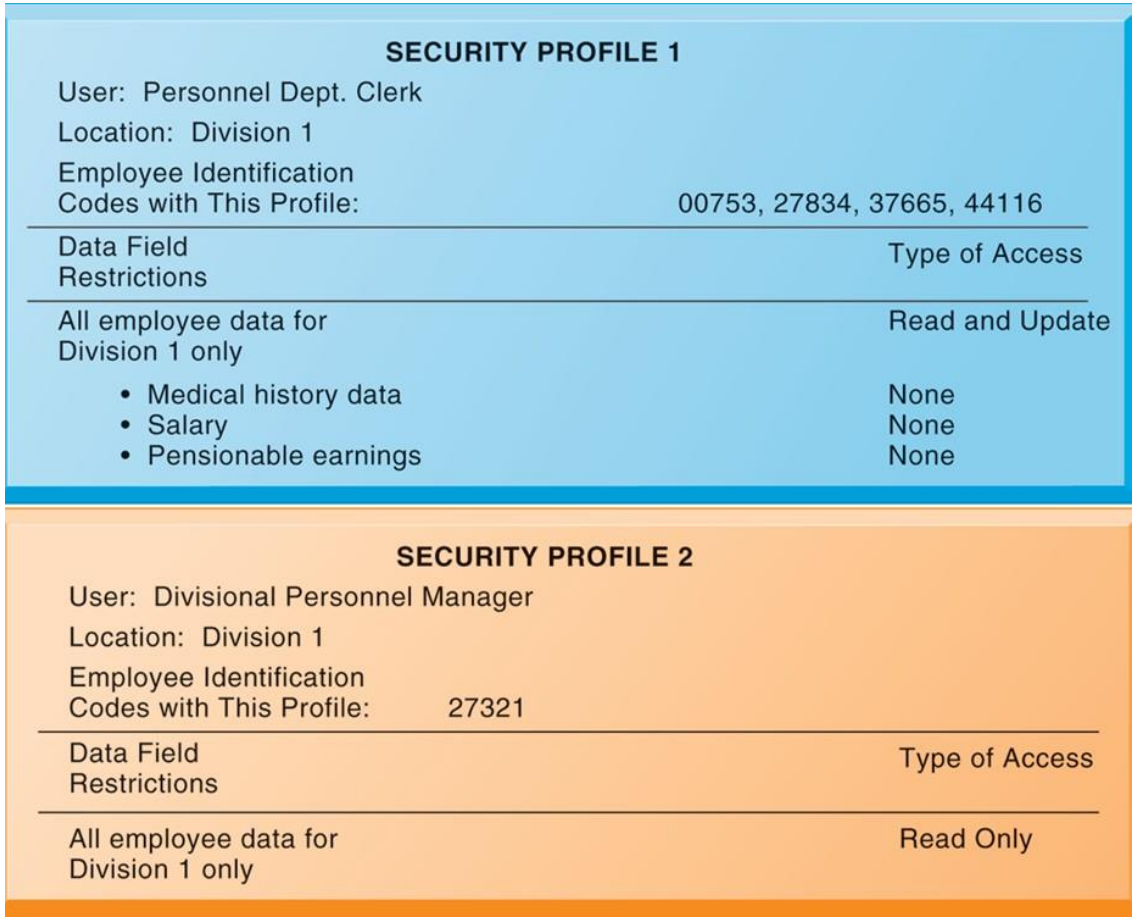
- Ranks information risks, identifies acceptable security goals, and identifies mechanisms for achieving these goals
- Drives other policies
  - Acceptable use policy (AUP)
    - Defines acceptable uses of firm's information resources and computing equipment
  - Authorization policies
    - Determine differing levels of user access to information assets

Identity Management

- Business processes and tools to identify valid users of system and control access
  - Identifies and authorizes different categories of users
  - Specifies which portion of system users can access
  - Authenticating users and protects identities

- Identity management systems
  - Captures access rules for different levels of users

Security Profiles for a Personnel System



SECURITY PROFILE 1

User: Personnel Dept. Clerk

Location: Division 1

Employee Identification Codes with This Profile: 00753, 27834, 37665, 44116

Data Field Restrictions	Type of Access
All employee data for Division 1 only	Read and Update
• Medical history data	None
• Salary	None
• Pensionable earnings	None

SECURITY PROFILE 2

User: Divisional Personnel Manager

Location: Division 1

Employee Identification Codes with This Profile: 27321

Data Field Restrictions	Type of Access
All employee data for Division 1 only	Read Only

These two examples represent two security profiles or data security patterns that might be found in a personnel system. Depending on the security profile, a user would have certain restrictions on access to various systems, locations, or data in an organization.

Disaster Recovery Planning & Business Continuity Planning

- Disaster recovery planning:
  - Devises plans for restoration of disrupted services

- Business continuity planning:
  - Focuses on restoring business operations after disaster
    - Both types of plans needed to identify firm's most critical systems
    - Business impact analysis to determine impact of an outage
    - Management must determine which systems restored first

Information Systems Audit

- Examines firm's overall security environment as well as controls governing individual information systems
- Reviews technologies, procedures, documentation, training, and personnel
- May even simulate disaster to test response of technology, IS staff, other employees
- Lists and ranks all control weaknesses and estimates probability of their occurrence
- Assesses financial and organizational impact of each threat

Sample Auditor's List of Control Weaknesses

Function: Loans **Location: Peoria, IL**	**Prepared by: J. Ericson** **Date: June 16, 2015**		**Received by: T. Benson** **Review date: June 28, 2015**	
Nature of Weakness and Impact	Chance for Error/Abuse		Notification to Management	
	Yes/ No	Justification	Report date	Management response
User accounts with missing passwords	Yes	Leaves system open to unauthorized outsiders or attackers	5/10/15	Eliminate accounts without passwords
Network configured to allow some sharing of system files	Yes	Exposes critical system files to hostile parties connected to the network	5/10/15	Ensure only required directories are shared and that they are protected with strong passwords
Software patches can update production programs without final approval from Standards and Controls group	No	All production programs require management approval; Standards and Controls group assigns such cases to a temporary production status		

This chart is a sample page from a list of control weaknesses that an auditor might find in a loan system in a local commercial bank. This form helps auditors record and evaluate control weaknesses and shows the results of discussing those weaknesses with management, as well as any corrective actions taken by management.

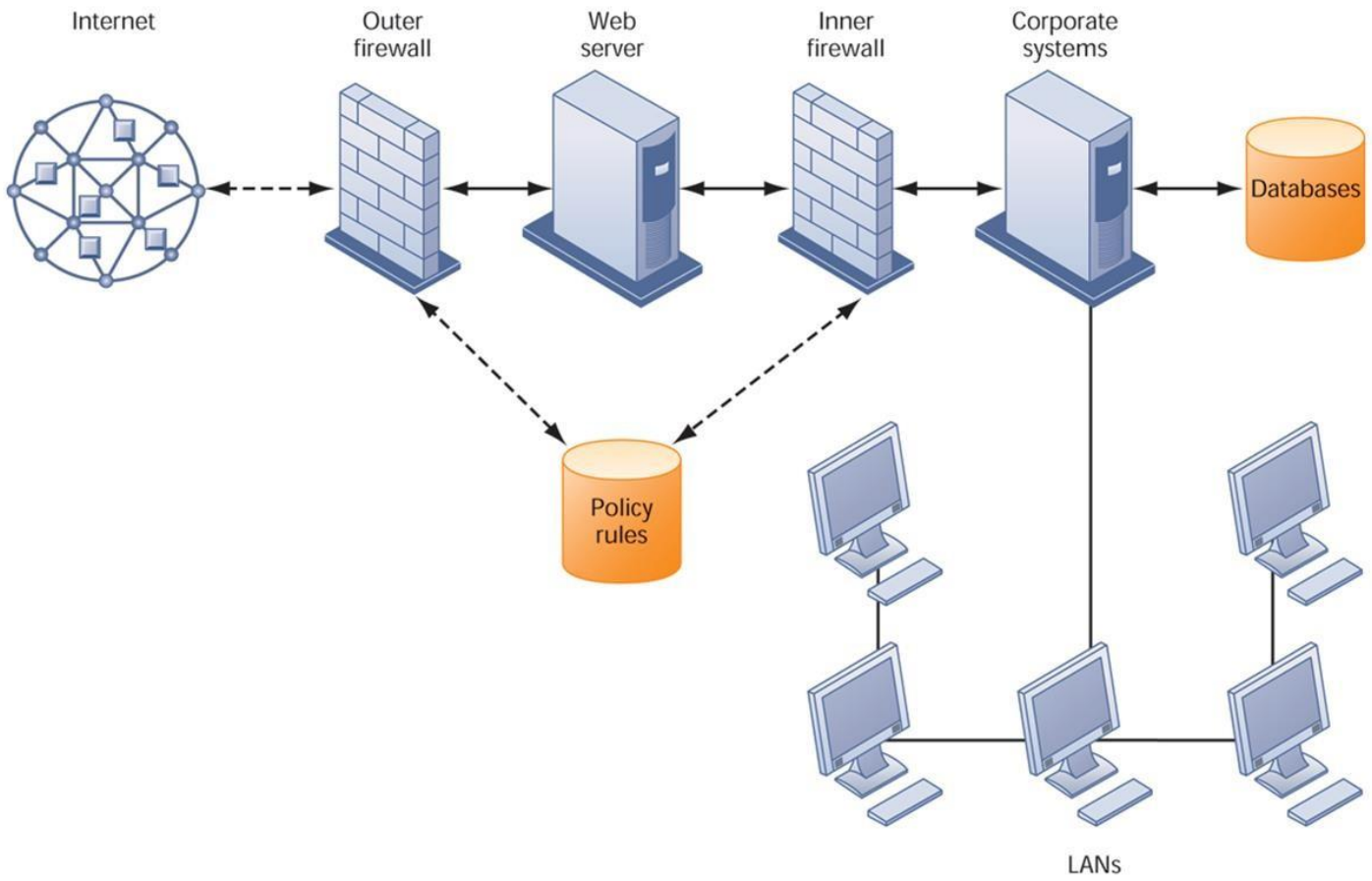
Tools and Technologies for Safeguarding Information Resources

- Identity management software
  - Automates keeping track of all users and privileges
  - Authenticates users, protecting identities, controlling access
- Authentication
  - Password systems
  - Tokens
  - Smart cards
  - Biometric authentication
  - Two-factor authentication

Tools and Technologies for Safeguarding Information Resources

1. Firewall:
   - Combination of hardware and software that prevents unauthorized users from accessing private networks
   - Technologies include:
     - Static packet filtering
     - Stateful inspection
     - Network address translation (NAT)
     - Application proxy filtering

A Corporate Firewall



The firewall is placed between the firm's private network and the public Internet or another distrusted network to protect against unauthorized traffic.

Tools and Technologies for Safeguarding Information Resources

2. Intrusion detection systems:
   - Monitors hot spots on corporate networks to detect and deter intruders
   - Examines events as they are happening to discover attacks in progress
3. Antivirus and antispyware software:
   - Checks computers for presence of malware and can often eliminate it as well
   - Requires continual updating
4. Unified threat management (UTM) systems

Tools and Technologies for Safeguarding Information Resources

5. Securing wireless networks
   - WEP security can provide some security by:
     - Assigning unique name to network's SSID and not broadcasting SSID
     - Using it with VPN technology
   - Wi-Fi Alliance finalized WPA2 specification, replacing WEP with stronger standards
     - Continually changing keys
     - Encrypted authentication system with central server

Tools and Technologies for Safeguarding Information Resources

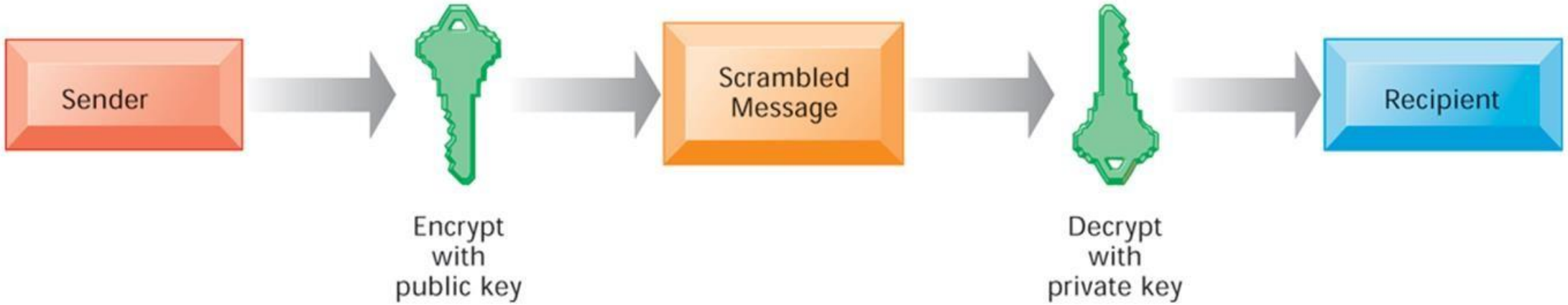
6. Encryption:
   - Transforming text or data into cipher text that cannot be read by unintended recipients
   - Two methods for encryption on networks
     1) Secure Sockets Layer (SSL) and successor Transport Layer Security (TLS)
     2) Secure Hypertext Transfer Protocol (S-HTTP)

Two Methods of Encryption

1) Symmetric key encryption
   - Sender and receiver use single, shared key

2) Public key encryption
   - Uses two, mathematically related keys: Public key and private key
   - Sender encrypts message with recipient's public key
   - Recipient decrypts with private key

Public Key Encryption

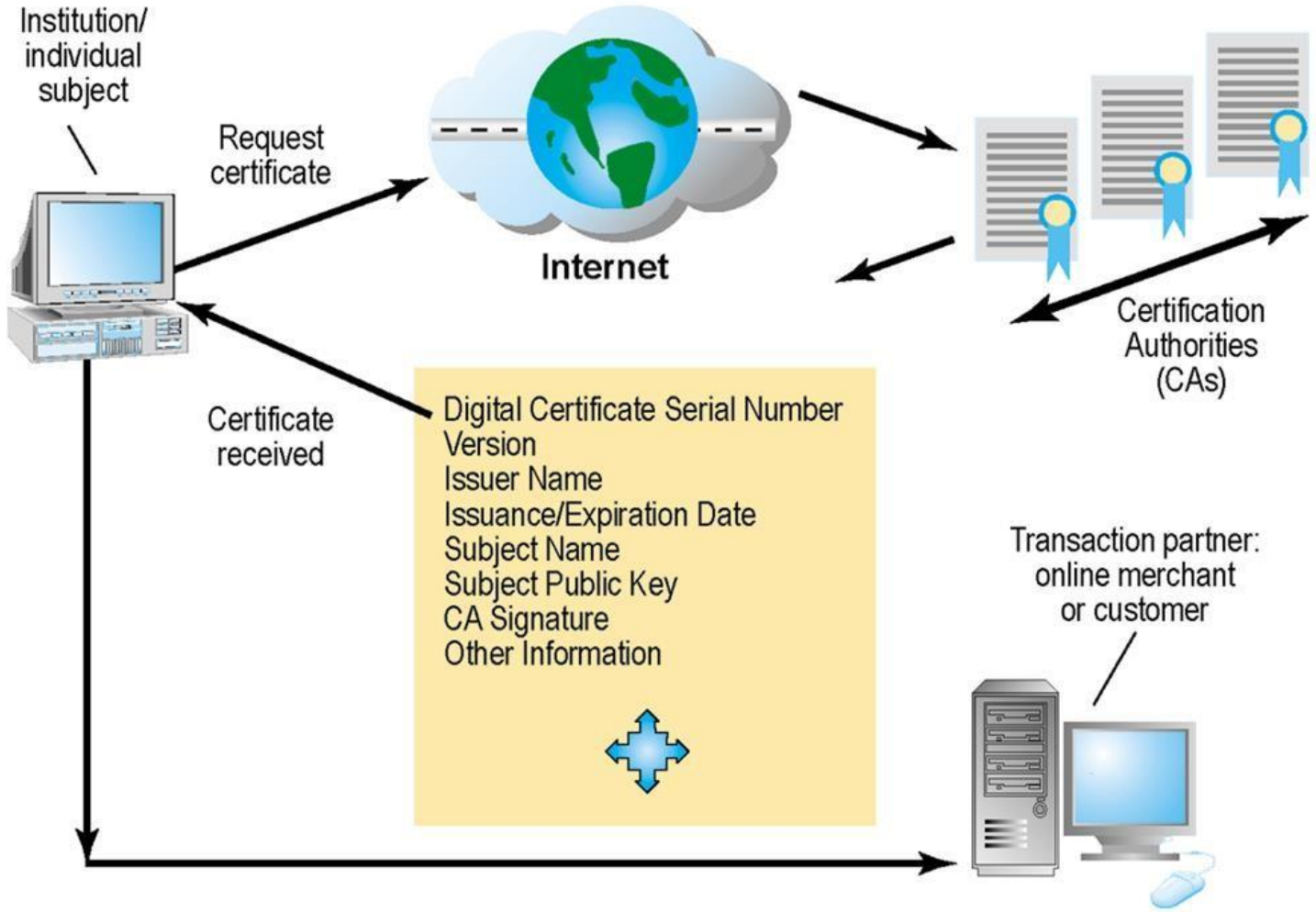


A public key encryption system can be viewed as a series of public and private keys that lock data when they are transmitted and unlock the data when they are received.The sender locates the recipient's public key in a directory and uses it to encrypt a message. The message is sent in encrypted form over the Internet or a private network.When the encrypted message arrives, the recipient uses his or her private key to decrypt the data and read the message.

Tools and Technologies for Safeguarding Information Resources

7. Digital certificate:
   - Data file used to establish the identity of users and electronic assets for protection of online transactions
   - Uses a trusted third party, certification authority (CA), to validate a user's identity
   - CA verifies user's identity, stores information in CA server, which generates encrypted digital certificate containing owner ID information and copy of owner's public key
8. Public key infrastructure (PKI)
   - Use of public key cryptography working with certificate authority
   - Widely used in e-commerce

Digital Certificates



Digital certificates help establish the identity of people or electronic assets. They protect online transactions by providing secure, encrypted, online communication.

Tools and Technologies for Safeguarding Information Resources

9. Ensuring system availability
   - Online transaction processing requires 100% availability, no downtime

10. Fault-tolerant computer systems
    - For continuous availability, for example, stock markets
    - Contain redundant hardware, software, and power supply components that create an environment that provides continuous, uninterrupted service

Tools and Technologies for Safeguarding Information Resources

11. Controlling network traffic
    - Deep packet inspection (DPI)
        - Examines data files and sorts low-priority material
        - Can block video and music downloads

12. Security outsourcing
    - Managed security service providers (MSSPs)

Tools and Technologies for Safeguarding Information Resources

13. Security in the cloud
    - Responsibility for security resides with company owning the data
    - Firms must ensure providers provides adequate protection:
        - Where data are stored
        - Meeting corporate requirements, legal privacy laws
        - Segregation of data from other clients
        - Audits and security certifications
    - Service level agreements (SLAs)

Tools and Technologies for Safeguarding Information Resources

14. Securing mobile platforms

- Security policies should include and cover any special requirements for mobile devices
  - Guidelines for use of platforms and applications
- Mobile device management tools
  - Authorization
  - Inventory records
  - Control updates
  - Lock down/erase lost devices
  - Encryption
- Software for segregating corporate data on devices

Tools and Technologies for Safeguarding Information Resources

15. Ensuring software quality

- **Software metrics:** Objective assessments of system in form of quantified measurements
  - Number of transactions
  - Online response time
  - Payroll checks printed per hour
  - Known bugs per hundred lines of code
- Early and regular testing
- **Walkthrough:** Review of specification or design document by small group of qualified people
- **Debugging:** Process by which errors are eliminated

References

- Management Information Systems 17th Edition by Laudon, K. C., & Laudon, J. P

Questions ???



Thank you…